

OMNIROUTE LOGISTICS

CYBER PREPAREDNESS REPORT

The Gentlemen Ransomware Threat Assessment

How can OmniRoute stop The Gentlemen from turning an initial intrusion into a ransomware attack that disrupts its global logistics operations?

Prepared for	Chief Information Security Officer OmniRoute Logistics
Prepared by	Squad 4 Cyber Preparedness Task Force
Team members	Grace Weyama Andrew Kiema Arcel Mukadi Kabamba Benard Emmanuel Kariuki David Mwangi Denis Kyalo Ndemwa Gatanna Gachiri Waruinge Joseph Kirutu Tiffany Murithi
Date	2 September 2026

Document Control

Purpose	To help OmniRoute's leadership understand the ransomware risk posed by The Gentlemen and determine the actions needed to strengthen prevention, detection, response, and recovery.
Scope	Adversary Characterisation, Organisational Concerns & Consequences, Cyber Preparedness Strategy (including lifecycle mapping and incident response priorities), and Detection Engineering Analysis.
Primary frameworks and guidance	Cyber Preparedness Adversary Class Framework; MITRE ATT&CK; NIST Cybersecurity Framework (CSF) 2.0; NIST SP 800-61 Rev. 3.
Evidence basis	The assessment is based on the case brief and supported by cited public threat intelligence and guidance from government agencies and technology vendors.
Implementation timeline	Address known exposures immediately, reduce the most critical risks within 90 days, and implement the Architectural Resilience program over the next 12 months.

Table of Contents

Document Control	2
Executive Summary.....	4
1. Adversary Characterisation	5
1.1 Adversary Class Selection	5
1.2 Primary Goals	5
Supporting objectives:	6
1.3 Operational Timeframe & Persistence	6
1.4 Stealth & Defense Evasion	7
1.5 Adversary Profile Statement	8
2. Organisational Concerns & Consequences	8
2.1 Goal-to-Consequence Mapping	8
2.1.1 Extortion / Ransom Demand.....	8
2.1.2 Data Exfiltration and Double Extortion	9
2.1.3 Operational Disruption	9
2.1.4 Backup and Recovery Inhibition	10
2.2 Consequence Severity Matrix	10
3. Cyber Preparedness Strategy	11
3.1 Cyber Attack Lifecycle Mapping	11
3.2 Incident Response Priorities	12
3.3 Overall Preparedness Posture	12
4. Detection Engineering Analysis	13
4.1 OriginalFileName vs Image.....	14
4.2 EID 1 Triage Fields	14
4.3 EID 11 Coverage Gap.....	15
5. Conclusion & Recommendations	16
5.1 Conclusion	16
5.2 Prioritised Recommendations	17
5.3 Open Risks & Assumptions for Board Validation.....	17
References	18
Appendix A - TTP-to-Control Matrix	19
Appendix B - 12-Month Cyber Preparedness Roadmap.....	20

Executive Summary

The Gentlemen is a financially motivated ransomware group that has been active since around mid-2025. Its attacks combine data theft with ransomware deployment, giving the group two ways to pressure victims: disrupt operations and threaten to publish stolen information. This makes the threat especially relevant to OmniRoute because the company relies heavily on FortiGate and FortiProxy infrastructure, which the group has been known to target through exploitation of CVE-2024-55591. The Gentlemen also uses valid accounts, PowerShell, WMI, RDP, Group Policy changes, scheduled tasks, registry persistence, defense evasion, data exfiltration, and disruption of recovery mechanisms. (Microsoft Threat Intelligence, 2026; Fortinet, 2025)

These behaviors fit the Cyber Breach & Organisational Disruption adversary class. The group is not simply looking to gain access to systems; its goal is to steal data, disrupt business operations, make recovery more difficult, and use that pressure to increase the chances of a ransom payment.

For OmniRoute, the impact could be significant. The company operates across 42 countries, serves more than 1,800 enterprise clients, and processes over 600,000 shipment records each day. A successful intrusion could affect shipment visibility, customs processing, warehouse operations, and customer commitments. If sensitive client, cargo, financial, or operational data is stolen, the consequences could continue long after systems are restored, including regulatory obligations, reputational damage, and continued extortion pressure.

This report recommends Architectural Resilience as the most suitable preparedness posture for OmniRoute. The first priority is to identify and address any current FortiGate and FortiProxy exposure, check for signs of earlier compromise, restrict unnecessary management access, rotate privileged and VPN credentials, and conduct a targeted threat hunt across the environment.

Over the next 90 days and beyond, OmniRoute should focus on stronger network segmentation, tighter privileged access, better monitoring of identity and administrative activity, and recovery capabilities that can still be trusted if production systems are compromised. Immutable backups, clean restoration procedures, and regular recovery testing should form a core part of that approach, in line with NIST CSF 2.0 and NIST SP 800-61 Rev. 3. (NIST, 2024; NIST, 2025)

Immediate executive priority

Approve an immediate review of OmniRoute's FortiGate and FortiProxy environment for both current exposure and signs of earlier compromise. This should include restricting unnecessary management access, rotating privileged and VPN credentials, and hunting for indicators of The Gentlemen's activity across the environment before moving into the wider 90-day resilience program.

1. Adversary Characterisation

This section assesses The Gentlemen against the Cyber Preparedness adversary-class framework provided with the assessment. Based on the group's observed TTPs, operational behaviour, persistence, defense evasion, and ability to disrupt business operations, The Gentlemen is best classified as a Cyber Breach & Organisational Disruption adversary. The sections that follow explain the evidence supporting that classification and why the other adversary classes are a weaker fit.

1.1 Adversary Class Selection

Selected class: Cyber Breach & Organisational Disruption.

The Gentlemen fits the Cyber Breach & Organisational Disruption class because its attacks are designed to cause more than a simple system compromise. Once access is gained, the group works to expand its control, weaken security defenses, steal sensitive data, disrupt recovery, and eventually encrypt systems in a way that can affect the wider business.

This pattern is consistent with the group's known use of Fortinet exploitation, compromised credentials, lateral movement, anti-EDR techniques, data exfiltration, and backup disruption. Together, these behaviors show an adversary that is able to turn an initial technical breach into a broader operational problem, which is the key reason this class is the strongest fit.

Competing class	Why it is not the primary fit	What evidence would change the assessment
Cyber Vandalism	The Gentlemen is more capable and organized than a typical vandalism threat. It steals data, moves across networks, disable security controls, and uses extortion for financial gain.	Evidence that the group mainly carried out defacement, DDoS, or other short-lived attacks with little persistence or extortion.
Cyber Incursion	The group does more than gain limited access. It maintains persistence, moves laterally, steals data, disrupts recovery, and encrypts systems.	Evidence that the group usually gained access only for resale or another limited objective, without causing wider business disruption.
Cyber Espionage & External Disruption	The Gentlemen is technically capable, but its main goal is financial extortion rather than long-term intelligence collection or state objectives.	Evidence that the group is state-sponsored or carrying out intelligence gathering or disruption for strategic rather than financial reasons.
Cyber-Supported Strategic Disruption	There is no evidence that the group is part of a wider geopolitical or state-level disruption campaign. Its known activity remains financially motivated.	Evidence that its attacks were coordinated to disrupt governments, critical national services, or geopolitical targets.

Source: Appendix A adversary-class framework and scenario TTPs.

1.2 Primary Goals

The Gentlemen's main goals are financial gain and disruption of business operations. Persistence and defense evasion support those goals by helping the group maintain access, avoid detection, steal data, and make recovery more difficult.

Goal	Observed TTPs / behaviour	Victim-level effect	OmniRoute relevance
Financial extortion	T1486 Data Encrypted for Impact; T1041/T1048 exfiltration; Tor leak-site pressure	Combines system disruption with the threat of exposing stolen data, increasing pressure on the victim to pay.	Disruption to logistics services, together with the possible release of client, cargo, and financial data, would increase pressure on OmniRoute during ransom negotiations.
Operational coercion	T1490 Inhibit System Recovery; T1484.001 Group Policy Modification; T1021.001 RDP; WMI/PowerShell propagation	Spreads the attack, limits recovery options, and turns a technical compromise into a wider business outage.	OmniRoute depends on continuous shipment visibility, customs processing, warehousing, and shared services, so disruption could quickly affect operations across multiple regions.
Reputational and disclosure pressure	T1041/T1048 encrypted data exfiltration and public leak-site publication	Uses the threat of exposing sensitive business and customer data to damage trust and increase pressure to pay.	A public data leak could damage trust among OmniRoute's enterprise clients and create reputational harm that continues even after systems are restored.

Source: Assessment-provided TTP reference, supported by Cybereason, Trend Micro, SOCRadar, eSecurity Planet, and Cyber Daily reporting.

Supporting objectives:

The Gentlemen uses persistence and defense evasion to maintain access and reduce the chance of detection. Techniques such as scheduled tasks, registry run keys, valid accounts, registry modification, and defense impairment help the group stay in the environment long enough to steal data, disrupt recovery, and deploy ransomware successfully.

1.3 Operational Timeframe & Persistence

Open-source reporting, citing ZeroFox intelligence, suggests that The Gentlemen may remain in a victim environment for around two to six weeks before deploying ransomware. Because it operates as a Ransomware-as-a-Service group, the timing can vary between affiliates.

For OmniRoute, this creates an important detection window. Unusual account activity, network discovery, persistence, defense evasion, and lateral movement may be visible before encryption begins, giving defenders a chance to contain the attack early. (The Hacker News, 2026)

Source: <https://thehackernews.com/2026/06/the-gentlemen-ransomware-claims-478.html>

Persistence / access mechanism	Why it helps the attacker stay in the environment	What defenders should look for
T1053.005 - Scheduled Task/Job	A scheduled task can restart the payload after a reboot and may run with SYSTEM privileges, helping the attacker maintain access.	New or unusual scheduled tasks, task-file creation, unexpected task names or actions, and SYSTEM-level execution from unusual locations.
T1547.001 - Registry Run Keys / Startup Folder	Run and RunOnce keys can automatically launch malware when a user logs in or the system starts, allowing persistence across reboots.	Changes to Run/RunOnce registry keys, unfamiliar autorun entries, and references to unexpected or suspicious binaries.
T1078.002 - Valid Domain Accounts	Stolen credentials can let the attacker regain access even after malware is removed and can also be used to move laterally across the network.	Unusual VPN or admin logins, impossible travel, logins from new locations, privileged account activity, and unusual RDP, WinRM, or WMI activity.

Source: Assessment-provided TTP reference; Microsoft Threat Intelligence, 2026.

1.4 Stealth & Defense Evasion

The Gentlemen has a high level of defense-evasion capability. The group does not rely on one technique alone. Instead, it combines several methods to weaken security tools, reduce visibility, and make its activity harder to spot. It also uses legitimate administrative tools, which can help malicious activity blend in with normal day-to-day operations.

Technique	Observed behaviour	Why it is effective	Defender response
T1562.001 - Impair Defenses	The group uses All.exe, ThrottleBlood.sys (BYOVD), and Allpatch2.exe variants to stop EDR/AV tools. Windows Defender may also be disabled before execution.	Disabling security tools reduces visibility and gives the attacker more freedom to operate.	Block vulnerable drivers, enable tamper protection, monitor driver loads and security-service stops, and use EDR health monitoring.
T1112 - Modify Registry	WMI AutoLogger and GlobalLogger settings are changed to reduce event logging.	This creates gaps in SIEM and EDR visibility and makes investigation harder.	Alert on protected registry changes, centralize logs, forward key telemetry off-host, and monitor configuration changes.
Living-off-the-land execution	PowerShell and WMI are used for remote execution and lateral movement, while RDP is used for interactive access.	These are legitimate admin tools, so malicious activity can blend in with normal operations.	Restrict WinRM, WMI, and RDP, record command lines, and monitor unusual remote administration and lateral logons.
Anti-forensics / evidence reduction	The group may remove event logs, Defender artefacts, RDP logs, PowerShell history, and shadow copies.	Removing evidence makes detection and forensic investigation more difficult.	Send logs to protected central storage, alert on wevtutil, vssadmin, and wmic abuse, and protect backup and EDR telemetry.

Source: Assessment TTP reference, supported by Trend Micro (2025), Microsoft Threat Intelligence (2026), and Cybereason.

1.5 Adversary Profile Statement

The Gentlemen is a financially motivated Ransomware-as-a-Service group capable of turning an initial foothold into a much wider business disruption. It uses stolen credentials, lateral movement, defense evasion, data theft, and encryption to increase pressure on victims and make recovery more difficult.

OmniRoute is particularly exposed because of its reliance on FortiGate and FortiProxy infrastructure, which the group has been known to target through CVE-2024-55591. Once inside, The Gentlemen can use domain credentials, Group Policy, PowerShell, WMI, scheduled tasks, and registry persistence to move deeper into the environment and reach shared systems.

For OmniRoute, the real risk is not one encrypted machine, but an attack that spreads across the environment, disrupts logistics operations, exposes sensitive data, and weakens recovery at the same time.

2. Organisational Concerns & Consequences

OmniRoute's exposure needs to be viewed in the context of how the business operates. The company spans 42 countries, runs three on-premises data centers, relies heavily on FortiGate across its global WAN, processes more than 600,000 shipment records each day, and supports over 1,800 enterprise clients, including healthcare and government organisations.

A successful attack would therefore affect more than IT systems. The analysis below focuses on how The Gentlemen's activity could translate into operational disruption, financial loss, regulatory exposure, and loss of customer trust.

2.1 Goal-to-Consequence Mapping

2.1.1 Extortion / Ransom Demand

Primary TTPs: T1486 Data Encrypted for Impact; T1021.001 RDP; T1059.001 PowerShell; T1047 WMI.

Expected cyber effects:

- Encryption of Windows endpoints, servers, network shares, and virtualized systems supporting OmniRoute's logistics platform.
- Loss of access to shipment records, customs workflows, warehouse services, shared files, and administrative systems.
- Rapid spread across connected systems, increasing the risk that the incident affects multiple countries rather than remaining limited to one site.

Organisational consequences:

- **Service interruption and contractual exposure:** Delays to shipment tracking and processing could affect customer SLAs and create knock-on disruption across healthcare, retail, manufacturing, and government supply chains.
- **Financial pressure:** OmniRoute could face lost productivity, emergency response and recovery costs, possible contractual penalties or service credits, and pressure from the ransom demand.

- **Executive decision pressure:** A large-scale disruption would force leadership to make time-sensitive decisions on ransom response, communications, legal obligations, and recovery priorities.

2.1.2 Data Exfiltration and Double Extortion

Primary TTPs: T1041/T1048 Exfiltration Over C2 / Alternate Protocol; encrypted TOX channels; Tor leak-site publication.

Expected cyber effects:

- Theft of cargo information, route details, delivery schedules, client data, financial records, and other operational documents before encryption begins.
- Sensitive data could leave OmniRoute without causing an immediate outage, meaning the breach may become a regulatory and customer issue even if ransomware deployment is stopped.
- Stolen information may be selectively leaked or threatened with publication to increase pressure during ransom negotiations.

Organisational consequences:

- **Regulatory and notification exposure:** If personal or regulated data is affected, OmniRoute may need to notify regulators and customers under GDPR, the Kenya Data Protection Act, and other applicable laws.
- **Lasting confidentiality impact:** Once data has been stolen, it cannot simply be made private again. Client, cargo, and operational information may remain exposed even after systems are restored.
- **Customer trust and commercial impact:** Customers, especially those in regulated sectors, may ask for evidence of containment, a clear understanding of what data was affected, and proof that security controls have been improved before fully restoring confidence.

2.1.3 Operational Disruption

Primary TTPs: T1486 encryption; T1484.001 Group Policy Modification; T1021.001 RDP; T1047 WMI; T1018 Remote System Discovery.

Expected cyber effects:

- Ransomware deployment and lateral movement could spread across multiple regions and affect shared enterprise services at the same time.
- Shipment visibility, customs processing, warehouse operations, customer portals, and internal coordination could be disrupted or become unavailable.
- If shared storage or virtualized infrastructure is encrypted, several dependent applications could fail at once.

Organisational consequences:

- **Supply-chain impact:** If OmniRoute loses visibility over shipments for an extended period, customers could also experience delays and disruption to their own operations.
- **Safety and compliance pressure:** Healthcare and government shipments may need to be prioritized, handled manually, and checked carefully to make sure shipment information has not been affected.
- **Cross-border coordination challenges:** A response across 42 countries would involve different time zones, legal requirements, teams, and systems. If responsibilities are not clear in advance, containment and recovery could take longer.

2.1.4 Backup and Recovery Inhibition

Primary TTP: T1490 Inhibit System Recovery; supporting behaviors include security-service termination and firewall-rule changes.

Expected cyber effects:

- Backup and recovery services could be disabled before encryption, and shadow copies may be deleted to remove local recovery options.
- If privileged accounts are compromised, online backups could also be at risk, especially where they share credentials or network access with production systems.
- Recovery may take longer if clean restore points cannot be trusted or if the attacker still has access to identity or management systems.

Organisational consequences:

- **Longer outage and complex recovery:** Recovery may go beyond simply restoring systems. OmniRoute could need to validate affected systems, reset compromised identities, rebuild critical infrastructure, and restore services in stages.
- **Risk of data loss:** If recent backups are encrypted, deleted, or cannot be trusted, OmniRoute may have to restore older data and manually reconcile shipment records.
- **Reduced negotiating leverage:** If reliable recovery options are limited, OmniRoute may become more dependent on the attacker's decryption of data, increasing the pressure to pay the ransom.

2.2 Consequence Severity Matrix

Consequence area	Severity	Justification
Financial Loss	Severe / Long-term	A major outage could bring together recovery costs, lost productivity, contractual penalties, regulatory costs, and continued security spending.
Operational Disruption	Severe / Long-term	OmniRoute processes more than 600,000 shipment records each day across 42 countries, so disruption could affect both its own operations and customer supply chains.
Reputation Damage	Extensive / Mid-term	A public data leak or prolonged outage could damage customer trust, although confidence can be rebuilt over time through a clear response and visible security improvements.
Legal / Regulatory Liability	Severe / Long-term	A cross-border data breach could trigger notification, investigation, remediation, contractual, and record-keeping obligations in several jurisdictions.
Customer / Partner Impact	Severe / Long-term	More than 1,800 enterprise customers could be affected by service disruption and may require technical, contractual, and assurance support.
Data Integrity / Confidentiality Loss	Severe / Long-term	Stolen or altered client, cargo, or financial data could create lasting confidentiality issues and require extended validation and notification.

Source: Severity ratings based on OmniRoute's operating environment and the mapped Gentlemen TTPs. The ratings are qualitative and are not intended to replace detailed financial impact modelling.

Regulatory timing matters

If personal data is involved, OmniRoute may have only a short window to assess the breach and meet its notification obligations. GDPR and Kenya's Data Protection Act both use a 72-hour notification period for qualifying breaches, while other jurisdictions may have their own reporting requirements. Legal and privacy teams should therefore be involved early, rather than waiting until technical containment is complete.

3. Cyber Preparedness Strategy

OmniRoute should adopt **Architectural Resilience** as its overall preparedness strategy. The focus is not only on preventing an initial compromise, but also on limiting the damage if an attacker gets in, detecting malicious activity before ransomware is deployed, and making sure the business can recover without depending on compromised systems.

The controls in this section are organized around the six phases of the Cyber Attack Lifecycle and aligned with the NIST CSF 2.0 functions: Govern, Identify, Protect, Detect, Respond, and Recover. This gives OmniRoute a practical way to connect prevention, detection, response, and recovery into one coordinated approach.

3.1 Cyber Attack Lifecycle Mapping

Phase	Expected Gentlemen activity against OmniRoute	Detection methods	Response actions
Recon	Look for exposed FortiGate/FortiProxy devices, VPN portals, management interfaces, credentials, and high-value systems. Once inside, use AD queries and network scanning to map the environment.	Track internet-facing assets and Fortinet versions. Monitor exposed credentials, unusual scanning, AD enumeration, LDAP/SMB activity, and tools such as Nmap or Advanced IP Scanner.	Remove unnecessary exposure, restrict management access, reset exposed credentials, increase logging on targeted systems, and review related authentication activity.
Deliver	Target vulnerable FortiOS/FortiProxy systems (T1190) or use stolen VPN/domain credentials (T1078.002) to gain access and stage tools.	Review FortiGate/FortiProxy admin and VPN logs, suspicious successful logins, new admin accounts, configuration changes, unusual file transfers, and EDR staging activity.	Isolate affected edge devices where possible, preserve logs and configuration, revoke sessions, rotate credentials, block known indicators, and check whether access happened before patching.
Exploit	Exploit CVE-2024-55591 or abuse valid credentials to gain privileged access and move towards directory and management systems.	Monitor CISA KEV and Fortinet PSIRT alerts, privileged account activity, admin logins, configuration changes, CLI activity, and unusual internal connections.	Patch or upgrade affected devices, restrict management access, remove rogue accounts or configuration changes, rotate credentials, and preserve forensic evidence.
Control	Use RDP, PowerShell, WMI, valid accounts, and remote-access tools to maintain control and move laterally	Monitor RDP, WinRM, WMI, privileged logons, EDR process/network events, SMB/RPC traffic, firewall changes, and unusual admin sessions between regions.	Disable compromised accounts, isolate affected hosts or segments, restrict remote administration, collect volatile evidence, and identify every system touched by the compromised account or host.

Phase	Expected Gentlemen activity against OmniRoute	Detection methods	Response actions
Execute	Disable security tools, modify logging, abuse Group Policy, steal data, stop recovery services, and deploy ransomware.	Watch for EDR tampering, driver loads, registry and GPO changes, unusual outbound traffic, backup-service stops, mass file changes, and ransomware behaviour.	Trigger the ransomware containment plan, isolate affected areas, protect backups, block data exfiltration and propagation, preserve evidence, and activate legal, privacy, and executive response teams.
Maintain	Use scheduled tasks, registry Run keys, valid accounts, and other access methods to survive reboots or partial cleanup.	Monitor Sysmon EID 1/11, registry changes, scheduled tasks, new services, identity logs, repeated logins, and configuration changes after containment.	Remove persistence only after the environment is fully scoped, rotate secrets and tokens, rebuild critical systems from trusted sources, confirm the attacker is gone, and restore services in stages.

Source: Assessment Cyber Attack Lifecycle and TTP references, supported by Fortinet PSIRT, CISA KEV, Microsoft Threat Intelligence, and NIST CSF 2.0.

3.2 Incident Response Priorities

Priority area	OmniRoute requirement	Why it matters
1. Incident management approach	Treat suspected Gentlemen activity as a Severity-1 incident. Use one incident commander, clear technical and business leads, regional contacts, and an out-of-band communication channel.	Clear ownership helps avoid delays, conflicting actions, and loss of evidence during a fast-moving incident.
2. Forensic analysis capability	Be ready to collect endpoint evidence, memory, FortiGate logs, AD/GPO activity, SIEM/EDR data, and network telemetry. Keep external DFIR support available if needed.	The group may remove logs or weaken security tools, so evidence needs to be preserved early.
3. Threat intelligence sources	Use Fortinet PSIRT, CISA KEV, industry ISACs, trusted vendor research, ransomware tracking, and internal detections. Track both IOCs and TTPs.	IOCs change quickly, while behaviors such as GPO abuse, PowerShell/WMI use, scheduled tasks, and recovery disruption remain useful for hunting.
4. External coordination	Maintain current contacts for regulators, legal counsel, law enforcement, insurers where relevant, vendors, industry partners, and critical customers.	A multinational incident can create legal, regulatory, and communication pressure at the same time.
5. Recovery strategy	Secure identity first, rebuild critical management systems, validate backups, restore key services from trusted recovery points, and reconnect systems in stages.	Restoring too early can reintroduce the attacker. Recovery should confirm that services are clean as well as available.

Source: NIST SP 800-61 Rev. 3 and the CISA StopRansomware Guide, supported by the assessment scenario.

3.3 Overall Preparedness Posture

Recommendation: Architectural Resilience

Architectural Resilience means designing the environment so that one compromise does not spread easily or prevent the business from recovering.

This is the best fit for OmniRoute because its systems are closely connected across multiple regions. A compromise at the edge could quickly affect identity services, shared infrastructure, logistics platforms, and recovery systems if those areas are not properly separated.

Basic Hygiene would help reduce common weaknesses, but it would not be enough against an attacker that may already have valid credentials or access to previously compromised devices. Critical Info Protection focuses mainly on protecting data, while Responsive Awareness improves detection without doing enough to limit the spread of an attack or protect recovery.

Pervasive Agility could be a longer-term goal, but it would require a higher level of automation and consistent visibility across the environment. For now, Architectural Resilience gives OmniRoute the most practical balance of prevention, containment, detection, and recovery.

Resilience pillar	Key controls	NIST CSF 2.0 emphasis	Outcome
Edge exposure & identity	Patch Fortinet devices, restrict admin access, enforce MFA, rotate credentials, and remove stale accounts.	Identify / Protect	Reduces the main entry points and limits credential abuse.
Segmentation & privilege boundaries	Separate critical systems and tightly control admin traffic between them.	Protect	Limits how far an attacker can move.
Threat-informed detection	Monitor EDR health, Fortinet logs, AD/GPO activity, Sysmon on key systems, and outbound traffic.	Detect	Helps detect the attack before ransomware is deployed.
Recovery architecture	Keep immutable backups, separate recovery credentials, and test restores regularly.	Protect / Recover	Keeps recovery available if production is compromised.
Incident command & external coordination	Maintain a Severity-1 playbook, out-of-band communications, DFIR support, and key external contacts.	Govern / Respond	Speeds up decisions and response.
Continuous validation	Run detection tests, purple-team exercises, recovery tests, and tabletop exercises.	Govern / Identify / Detect	Confirms that controls work in practice.

Source: NIST CSF 2.0 and the CISA StopRansomware Guide, with controls mapped to the assessment TTPs.

Preparedness principle

Assume prevention may fail. OmniRoute should be designed to limit how far an attacker can move, detect suspicious activity early, and recover without relying on compromised production systems.

4. Detection Engineering Analysis

A key persistence technique used by The Gentlemen is the creation of a scheduled task with schtasks.exe. In this scenario, the task is named WindowsUpdateService and launches C:\ProgramData\svchost.exe at system boot (T1053.005).

To detect this activity, OmniRoute can use two complementary Sysmon controls: EID 1 ProcessCreate to identify execution of schtasks.exe, including renamed copies through OriginalFileName, and EID 11 FileCreate to detect new files written to Windows scheduled-task directories.

The analysis below looks at what each control detects, where the gaps are, and how combining them improves detection coverage.

4.1 OriginalFileName vs Image

The Image field shows the path and filename used to create a process. If an attacker simply renames schtasks.exe to something like updater.exe, a detection rule that only looks at the visible filename may miss it.

OriginalFileName is more useful in this situation because it reads the executable’s embedded metadata. A renamed copy of schtasks.exe will often still identify itself as schtasks.exe, allowing Sysmon to detect the underlying tool even when the visible filename has changed. This helps defend against ATT&CK T1036 Masquerading.

This is relevant to The Gentlemen because the group has been reported to rename and repackage tools to avoid detection. The key point is that defenders should not rely on the visible filename alone. (Trend Micro, 2025)

OriginalFileName is still not enough on its own. An attacker can modify file metadata or use a different tool to create the task. For that reason, EID 1 should be reviewed together with the command line, parent process, user, hashes, and EID 11 task-file creation.

Field	Strength	Detection implication
Image	Shows the path and filename used to launch the process.	Useful for spotting execution from unusual locations, but a renamed <code>schtasks.exe</code> may be missed if the rule only looks at the visible filename.
OriginalFileName	Shows the original filename stored in the executable’s metadata.	Can still identify <code>schtasks.exe</code> after a simple rename, making basic masquerading harder to use for evasion.
Combined use	Looking at Image, OriginalFileName, CommandLine, and Hashes gives a fuller picture of the process.	Provides more reliable context and makes triage easier than relying on a single field.

Source: Assessment-provided Sysmon configuration, Microsoft Sysmon documentation, and MITRE ATT&CK T1036 Masquerading.

4.2 EID 1 Triage Fields

T1053.005 is the MITRE ATT&CK sub-technique for Scheduled Task/Job, where attackers abuse Windows Task Scheduler to run programs automatically, often to maintain persistence.

A T1053.005 alert on its own does not confirm malicious activity, because scheduled tasks are also commonly used for legitimate administration. The analyst needs to look at the surrounding process details to understand who created the task, how it was launched, what it is set to run, and whether the activity fits normal behaviour.

The EID 1 fields below provide that context and help distinguish legitimate task creation from The Gentlemen's persistence activity.

EID 1 field	What to check	Why it matters
Image	Check the full process path. Is schtasks.exe running from System32, or has it been copied or renamed elsewhere?	An unusual path or renamed copy can point to staging or masquerading.
OriginalFileName	Check whether the embedded filename still identifies the process as schtasks.exe.	Helps identify renamed copies of the legitimate tool.
CommandLine	Look for WindowsUpdateService, an ONSTART trigger, SYSTEM execution, and C:\ProgramData\svchost.exe.	These details closely match The Gentlemen's known persistence pattern.
ParentImage	Check what launched schtasks.exe, such as PowerShell, WMI, cmd.exe, or a remote service.	Can link task creation to remote execution or lateral movement.
ParentCommandLine	Review the parent process arguments for scripts, encoded PowerShell, or remote execution.	May reveal how the persistence activity started..
User / ParentUser	Check which account created the task and whether it is privileged or unexpected.	Compromised admin accounts or SYSTEM activity increase suspicion.
IntegrityLevel	Check whether the process is running with High or SYSTEM privileges.	Elevated execution may indicate persistence or privilege abuse.
Hashes	Compare the executable hash with known-good Microsoft files and known indicators.	Helps identify modified or suspicious binaries.
ProcessGuid / ParentProcessGuid	Use these values to link related Sysmon events.	Helps trace file, network, registry, and follow-on process activity.
LogonGuid / LogonId / TerminalSessionId / CurrentDirectory	Check the originating session, remote access context, and working directory.	Helps determine whether the task came from normal administration or suspicious remote activity.

Source: Microsoft Sysmon Event ID 1 documentation.

High-confidence correlation

Treat the alert as high priority when OriginalFileName identifies schtasks.exe and the command line creates WindowsUpdateService with an ONSTART trigger that runs C:\ProgramData\svchost.exe. Suspicion increases further if the task is launched through PowerShell, WMI, or a privileged remote session.

The analyst should then check for the matching EID 11 task-file creation event and review the referenced payload's hash and network activity.

4.3 EID 11 Coverage Gap

EID 11 gives OmniRoute a second way to spot scheduled-task persistence. While EID 1 shows that a process such as schtasks.exe ran, EID 11 shows that a task file was actually created under C:\Windows\System32\Tasks or C:\Windows\Tasks.

This matters because an attacker does not have to use schtasks.exe. For example, The Gentlemen could create WindowsUpdateService through PowerShell Register-ScheduledTask, the Task Scheduler API, or another custom tool. In that case, the EID 1 rule for schtasks.exe may not fire, but EID 11 can still detect the task file being written.

Using both events gives better coverage because one watches the process and the other watches the persistence artefact it creates.

Telemetry	What it shows	What it can miss	Best use
Sysmon EID 1 - ProcessCreate	Shows that a process such as schtasks.exe ran, including the command line, user, parent process, and hashes..	Can miss task creation through PowerShell, COM, or APIs that do not use the matched binary.	Understand how the task was created and what process or user was behind it.
Sysmon EID 11 - FileCreate	Shows that a file was created or changed in a scheduled-task directory.	Does not show the full command or session that created it and may include legitimate activity.	Confirm that a scheduled-task artefact was actually written.
Correlation	Brings together process activity, the task file, and user/session context.	Depends on central collection and accurate event timing.	Build a higher-confidence alert from multiple related signals.
Supplementary telemetry	Adds Task Scheduler logs, registry, EDR, PowerShell/WMI, GPO, and identity data.	Coverage depends on what is enabled across endpoints.	Fill detection gaps and support investigation..

Source: Assessment-provided Sysmon configuration, Microsoft Sysmon Event ID 1 documentation, and Microsoft Sysmon Event ID 11 documentation.

5. Conclusion & Recommendations

5.1 Conclusion

The Gentlemen is best classified as a Cyber Breach & Organisational Disruption adversary because its attacks are designed to turn an initial foothold into wider business disruption. Its use of stolen credentials, lateral movement, defense evasion, data theft, encryption, and recovery disruption creates a credible path from a single compromise to a much larger operational incident.

For OmniRoute, the risk is increased by its reliance on FortiGate and FortiProxy infrastructure and by the scale of its operations across multiple regions. A successful intrusion could disrupt logistics services, expose sensitive client and operational data, affect customer commitments, and create regulatory and recovery challenges.

OmniRoute should therefore continue with Architectural Resilience as its overall preparedness posture. The aim is to make initial compromise harder, limit how far an attacker can move, detect suspicious activity before ransomware is deployed, and maintain a trusted path to recovery. Success should be measured not only by whether encryption is prevented, but also by how quickly the intrusion is detected, contained, investigated, and safely recovered from.

5.2 Prioritised Recommendations

Priorit y	Recommendation	Target timing	Why it matters
1	Review all Fortinet exposure and signs of earlier compromise. Patch affected systems, restrict management access, rotate admin/VPN credentials, revoke sessions, review IoCs, and hunt for follow-on activity.	0-7 days	Addresses the most likely entry path and recognizes that patching alone does not remove previously stolen access.
2	Strengthen identity and limit lateral movement with separate admin accounts, PAM/PAWs or jump hosts, tighter GPO controls, segmentation, and restricted RDP/WinRM/WMI/SMB access.	0-30 days	Reduces the chance that one compromised account or host leads to wider ransomware spread.
3	Improve detection using Fortinet logs, EDR health monitoring, Sysmon on critical systems, GPO and registry monitoring, PowerShell/WMI visibility, backup-service alerts, and egress monitoring.	0-90 days	Gives defenders more chances to detect the attack before encryption and major business disruption.
4	Strengthen recovery with immutable or offline backups, separate recovery credentials, protected backup management, clean-room procedures, and regular restore testing.	0-180 days	Reduces downtime and keeps recovery possible even if production systems are compromised.
5	Maintain a tested Severity-1 ransomware playbook, out-of-band communications, DFIR support, regulator and law-enforcement contacts, customer communication plans, and regular tabletop exercises.	0-12 months, then continuous	Helps OmniRoute respond quickly, coordinate decisions, and meet legal and communication obligations during a major incident.

Source: Priorities are based on OmniRoute's identified exposure, The Gentlemen's TTPs, NIST CSF 2.0, NIST SP 800-61 Rev. 3, and CISA ransomware guidance.

5.3 Open Risks & Assumptions for Board Validation

Several important gaps still affect OmniRoute's residual risk and should be confirmed within the first 30 days:

- **Fortinet exposure:** Confirm FortiOS/FortiProxy versions, internet exposure, configurations, and any signs of earlier compromise across all regions.
- **Detection coverage:** Confirm current EDR, Sysmon, and logging coverage across endpoints, servers, virtualization platforms, and administrator workstations.
- **Privileged access:** Verify whether privileged accounts are separated, protected by MFA/PAM, restricted from normal user devices, and whether GPO changes are independently monitored.
- **Backup readiness:** Confirm backup immutability, offline separation, separate credentials, restore-test results, recovery-point age, and RTO/RPO for critical logistics services.
- **Data location and ownership:** Confirm where sensitive client, cargo, and employee data is stored and how data-protection responsibilities vary by jurisdiction.
- **Incident readiness:** Confirm DFIR support, cyber-insurance requirements, regulator contact procedures, and who has authority to isolate services across regions.

References

1. **Bodeau, D., & Graubart, R. (2017).** *Cyber Prep 2.0: Motivating Organizational Cyber Strategies in Terms of Threat Preparedness*. The MITRE Corporation.
URL: <https://www.mitre.org/news-insights/publication/cyber-prep-20-motivating-organizational-cyber-strategies-terms-threat>
2. **Fortinet. (2025).** *FG-IR-24-535: Authentication bypass in Node.js websocket module and CSF requests (CVE-2024-55591)*. FortiGuard PSIRT.
URL: <https://www.fortiguard.com/psirt/FG-IR-24-535>
3. **Cybersecurity and Infrastructure Security Agency (CISA).** *Known Exploited Vulnerabilities Catalog – CVE-2024-55591*.
URL: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
CISA lists CVE-2024-55591 as a known exploited Fortinet FortiOS/FortiProxy vulnerability and identifies it as known to have been used in ransomware campaigns.
4. **Group-IB. (2026, March 19).** *How Hastalamuerte Operates: Group-IB's Analysis of The Gentlemen's Attack Methods*.
URL: <https://www.group-ib.com/blog/hastalamuerte-gentlemen-raas-ttps/>
5. **Microsoft Threat Intelligence. (2026, May 28).** *The Gentlemen ransomware: Dissecting a self-propagating Go encryptor*. Microsoft Security Blog.
URL: <https://www.microsoft.com/en-us/security/blog/2026/05/28/the-gentlemen-ransomware-dissecting-a-self-propagating-go-encryptor/>
6. **Cybereason Threat Intelligence Team. (2025).** *License to Encrypt: "The Gentlemen" Make Their Move*.
URL: <https://www.cybereason.com/blog/the-gentlemen-ransomware>
7. **Trend Micro. (2025, September 9).** *Unmasking The Gentlemen Ransomware: Tactics, Techniques, and Procedures Revealed*.
URL: https://www.trendmicro.com/en_us/research/25/i/unmasking-the-gentlemen-ransomware.html
8. **SOCRadar. (2026, February 12).** *Dark Web Profile: The Gentlemen Ransomware*.
URL: <https://socradar.io/blog/dark-web-profile-the-gentlemen-ransomware/>
9. **eSecurity Planet. (2025, November 21).** *These 'Gentlemen' Aren't Gentle: Rapidly Evolving Ransomware Threat*.
URL: <https://www.esecurityplanet.com/threats/these-gentlemen-arent-gentle-rapidly-evolving-ransomware-threat/>
10. **Hollingworth, D. (2025, September 17).** *Introducing The Gentlemen, a new ransomware group who are anything but*. Cyber Daily.
URL: <https://www.cyberdaily.au/security/12648-introducing-the-gentlemen-a-new-ransomware-group-who-are-anything-but>
11. **SOS Ransomware. (2025, September 18).** *The Gentlemen: The new ransomware of autumn 2025*.
URL: <https://sosransomware.com/en/ransomware-groups/the-gentlemen-the-new-ransomware-of-autumn-2025/>
12. **The Hacker News. (2026, June 11).** *The Gentlemen Ransomware Claims 478 Victims, Can Spread Like a Worm*.
URL: <https://thehackernews.com/2026/06/the-gentlemen-ransomware-claims-478.html>
This is the source supporting the dwell-time discussion in Section 1.3.
13. **Ransomware.live.** *Ransomware victim and leak-site tracking database*.
URL: <https://www.ransomware.live/>
14. **MITRE ATT&CK.** *Enterprise ATT&CK Techniques*.
URL: <https://attack.mitre.org/techniques/>
15. **MITRE ATT&CK.** *T1053.005 – Scheduled Task/Job: Scheduled Task*.
URL: <https://attack.mitre.org/techniques/T1053/005/>
16. **MITRE ATT&CK.** *T1036.003 – Masquerading: Rename Legitimate Utilities*.
URL: <https://attack.mitre.org/techniques/T1036/003/>
17. **National Institute of Standards and Technology (NIST). (2024).** *The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29)*.
URL: <https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-csf-20/final>
DOI: <https://doi.org/10.6028/NIST.CSWP.29>
18. **National Institute of Standards and Technology (NIST). (2025).** *SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*.
URL: <https://csrc.nist.gov/pubs/sp/800/61/r3/final>
DOI: <https://doi.org/10.6028/NIST.SP.800-61r3>
19. **Microsoft Learn. (2026).** *Sysmon Events*.
URL: <https://learn.microsoft.com/en-us/windows/security/operating-system-security/sysmon/sysmon-events>

20. **Microsoft Learn. (2026).** *Sysmon Configuration Files*.
URL: <https://learn.microsoft.com/en-us/windows/security/operating-system-security/sysmon/sysmon-configuration-files>
21. **Cybersecurity and Infrastructure Security Agency (CISA). (2023).** *#StopRansomware Guide*.
URL: <https://www.cisa.gov/resources-tools/resources/stopransomware-guide>
22. **European Data Protection Board (EDPB).** *Personal Data Breaches*.
URL: https://www.edpb.europa.eu/topics/security-data-breaches/personal-data-breaches_en
This supports the GDPR breach-notification discussion, including the 72-hour requirement for qualifying breaches.
23. **Kenya Law. (2019).** *Data Protection Act, No. 24 of 2019*.
URL: <https://new.kenyalaw.org/akn/ke/act/2019/24/eng%402019-11-15>

Appendix A - TTP-to-Control Matrix

This appendix summarizes The Gentlemen's key TTPs and the controls OmniRoute can use to prevent, detect, and respond to them. It also provides a practical starting point for building and improving ATT&CK-based detection coverage.

TTP	Observed behaviour	Priority preventive control	Priority detective control
T1190	Exploitation of public-facing FortiOS/FortiProxy through CVE-2024-55591.	Patch affected systems, restrict management access, and harden configuration.	Track exposed assets, review Fortinet logs and IoCs, and alert on suspicious admin activity.
T1078.002	Use of valid domain or VPN accounts.	Enforce MFA, use PAM, separate admin accounts, rotate credentials, and remove stale accounts.	Monitor unusual logins, impossible travel, privileged access, and VPN activity.
T1059.001	PowerShell used for execution and lateral movement.	Limit administrative use, apply script controls, and enforce least privilege.	Review PowerShell logs, command lines, and EDR behavioral alerts.
T1047	WMI used for remote execution.	Restrict remote WMI and limit administrative access between network zones.	Monitor WMI activity, wmioprse.exe process chains, and remote execution patterns.
T1053.005	Scheduled tasks used for persistence.	Limit admin rights, harden service accounts, and use application control.	Monitor Sysmon EID 1 and EID 11, Task Scheduler logs, and unusual task actions.
T1547.001	Registry Run keys used for persistence.	Apply least privilege and application control.	Monitor registry changes, auto runs, and unexpected executable paths.
T1112	Registry changes used to reduce logging or weaken security controls.	Protect security settings and enable tamper protection.	Alert on changes to logging-related registry keys and other sensitive security settings.
T1562.001	Security tools impaired through BYOVD and related techniques.	Block vulnerable drivers, use application control, and enable EDR tamper protection.	Monitor driver loads, EDR health, security-service stops, and suspicious kernel activity.

TTP	Observed behaviour	Priority preventive control	Priority detective control
T1484.001	Group Policy modified to spread payloads or weaken controls.	Protect domain controllers, use tiered administration, and require controlled GPO changes.	Monitor GPO changes, permissions, and directory-service events.
T1018	Internal systems discovered through scanning and AD queries.	Segment networks and restrict unnecessary discovery paths.	Detect Nmap/Advanced IP Scanner activity and unusual SMB, LDAP, or ARP scanning.
T1021.001	RDP used for lateral movement.	Disable RDP where not needed, enforce MFA, and use controlled admin jump hosts.	Monitor RDP logons, unusual admin sessions, and abnormal source/destination patterns.
T1041/T1048	Data exfiltrated over encrypted or alternate channels.	Enforce egress filtering, proxy controls, and DLP.	Monitor unusual outbound traffic, DNS/proxy activity, and DLP alerts.
T1486	Data encrypted for impact.	Use segmentation, least privilege, application control, and protected backups.	Detect mass file changes, ransomware behaviour, canary-file activity, and unusual share writes.
T1490	Recovery options disabled or destroyed.	Keep immutable or offline backups with separate credentials and management access.	Monitor backup-service stops, shadow-copy deletion, backup-admin changes, and repository deletion attempts.

Source: Assessment-provided TTP reference table, with controls mapped to NIST, CISA, and Microsoft guidance.

Appendix B - 12-Month Cyber Preparedness Roadmap

This roadmap separates the work that OmniRoute should complete immediately from the longer-term changes needed to improve resilience across the organization. The first 90 days focus on reducing known exposure, improving visibility, limiting attacker movement, and proving that critical systems can be recovered. The remaining months focus on strengthening architecture, privileged access, detection coverage, and recovery readiness across the wider environment.

Window	Objectives	Core actions	Evidence of completion	Executive metric
0-7 days	Close immediate exposure and check whether The Gentlemen may already have gained access.	Review all internet-facing FortiGate and FortiProxy devices; patch or upgrade affected systems; restrict management access; rotate privileged and VPN credentials; review IoCs and configuration changes; hunt for signs of compromise; secure backup systems.	Fortinet inventory and patch records; credential-rotation record; threat-hunt findings; confirmation that backups are protected.	All internet-facing Fortinet assets reviewed and accounted for; no unexplained privileged access remains.
8-30 days	Improve visibility and secure the accounts most likely to be abused.	Centralise Fortinet logs; check EDR coverage and health; deploy Sysmon to domain controllers, critical servers, and admin endpoints; review privileged accounts and GPOs;	Telemetry coverage report; priority detections enabled; privileged-account inventory; backup	Critical systems are monitored and Tier-0 accounts are protected by MFA and

Window	Objectives	Core actions	Evidence of completion	Executive metric
		separate backup administration; confirm incident and regulatory contacts.	access review; updated escalation contacts.	controlled privileged access.
31-60 days	Make lateral movement harder and test whether suspicious activity can be contained quickly.	Restrict unnecessary RDP, WinRM, WMI, and SMB access; tighten administrative network paths; block vulnerable drivers; test ATT&CK-aligned detections; practice host isolation; close major EDR and logging gaps.	Segmentation changes; detection-test results; isolation exercise results; vulnerable-driver controls in place.	Test activity is detected before ransomware deployment and affected hosts can be isolated within the agreed response time.
61-90 days	Prove that critical services can be recovered and teams can work together during a ransomware incident.	Run a clean recovery exercise; restore Active Directory and at least one critical logistics service; conduct a ransomware tabletop with Security, Operations, Legal, and leadership; test customer communications; agree the remaining resilience priorities.	Restore results; measured RTO/RPO; tabletop findings; assigned actions and owners; approved resilience plan.	Critical recovery targets are met in testing and major outstanding risks have clear owners and deadlines.
3-6 Months	Reduce the chance that one compromised account or system can affect the wider environment.	Expand network segmentation; strengthen privileged-access controls; reduce standing admin rights; introduce controlled admin paths; improve identity monitoring; extend EDR and logging coverage across critical regions and systems.	Updated segmentation design; PAM coverage; privileged-access review; improved regional telemetry coverage; updated detection backlog.	Unrestricted administrative access and high-risk lateral movement paths are significantly reduced.
6-12 Months	Make recovery, testing, and security validation part of normal operations.	Expand immutable backup coverage; regularly test recovery of critical logistics services; run purple-team exercises; review Fortinet and identity exposure; improve incident playbooks; conduct cross-region exercises; track unresolved risks through governance reviews.	Recovery-test reports; purple-team findings; updated playbooks; resilience metrics; remediation tracking.	Critical services consistently meet recovery targets and high-risk attack paths are tested on a regular basis.

Source: Priorities based on The Gentlemen threat model and aligned with NIST CSF 2.0 and NIST SP 800-61 Rev. 3.